



SNOWBE ONLINE

PCI Policy

**Your name: Ethan Platt
Terell
Gabriel
Jardyel**

PCI Policy

Version1 DATE: 20251030

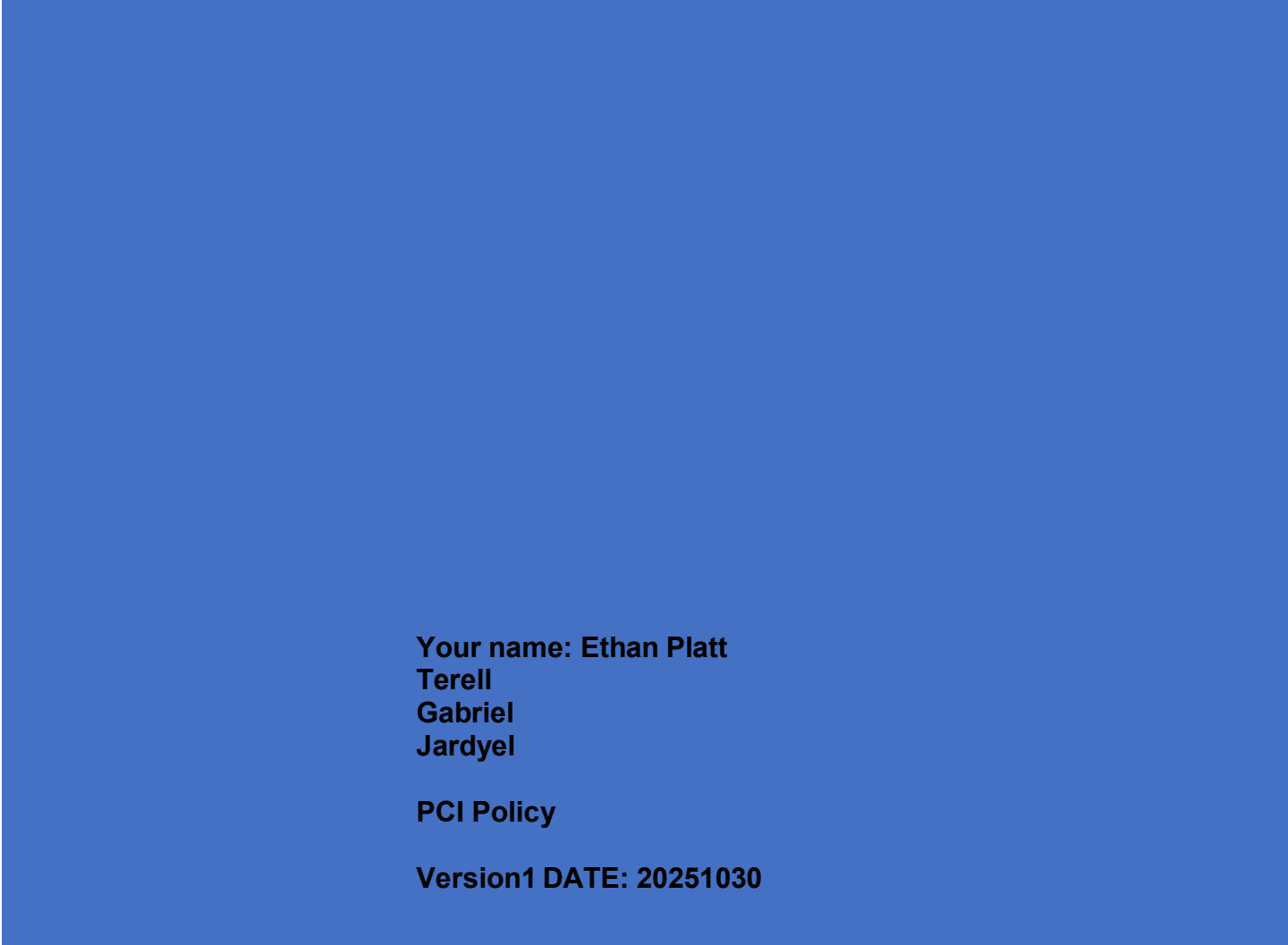


Table of Contents

PURPOSE..... 2

SCOPE..... 2

DEFINITIONS..... 2

ROLES & RESPONSIBILITIES 3

POLICY 3

EXCEPTIONS/EXEMPTIONS 4

ENFORCEMENT 4

VERSION HISTORY TABLE 4

CITATIONS 6

Purpose

The purpose of this PCI Compliance Policy is to establish requirements for protecting cardholder data handled by SnowBe Online in accordance with Payment Card Industry Data Security Standard (PCI DSS v4.0). This policy ensures all systems that store, process, or transmit payment card information are secure, monitored, and meet PCI standards. It provides guidelines for access control, encryption, vulnerability management, and incident response to protect customers, maintain trust, and reduce business risk.

Scope

This policy applies to:

- SnowBe must not store customer credit card numbers, CVVs, or magnetic stripe data indefinitely
- All employees, contractors, vendors, and consultants who access or manage systems processing, storing, or transmitting cardholder data (CHD).
- All SnowBe systems within the Cardholder Data Environment (CDE), including:
 - The AWS-hosted SnowBe e-commerce platform
 - Storefront POS terminals in the U.S. and Europe
 - VPNs used by remote employees accessing company applications
 - On-premises and cloud servers managing CRM, accounting, and customer data

External vendor payment processors are out of scope for direct management but must provide current PCI attestation certificates.

Definitions

Term	Definition
Cardholder Data (CHD)	Full Primary Account Number (PAN) or PAN with cardholder name, expiration date, or service code.
CDE (Cardholder Data Environment)	The network segment and connected systems where cardholder data is stored, processed, or transmitted.
Encryption	The process of converting sensitive data into an unreadable form using cryptographic algorithms to ensure confidentiality.
PAN (Primary Account Number)	The unique number on a credit or debit card that identifies the issuer and the individual account.
PCI DSS v4.0	The Payment Card Industry Data Security Standard, version 4.0. a global set of security requirements for protecting cardholder data.
Tokenization	The process of replacing cardholder data with a unique, randomly generated token that has no exploitable value.

Term	Definition
Vulnerability Scan	An automated process used to identify weaknesses or misconfigurations within systems, applications, and networks.

Roles & Responsibilities:

Role	Responsibilities
Employees (All)	Handle cardholder data responsibly, avoid storing CHD locally, complete annual PCI training, and report any suspicious activity immediately.
IT Director	Owns overall PCI compliance, approves controls (network segmentation, limit network access etc..) , oversees annual audits and assessments, and reports compliance status to executive leadership.
Security Manager	Implements and maintains PCI DSS technical and administrative controls, ensures encryption, access monitoring, and patch management are enforced, and coordinates PCI self-assessments (SAQs (self-assessment questionnaires)).
Store Managers	Maintain physical security of POS terminals, restrict device access to authorized personnel, train retail staff on PCI awareness, and report any on-site incidents.
System Administrators	Apply security patches, configure, and maintain firewalls, manage least-privilege access, and monitor logs for unauthorized activity.
Third-Party Vendors	Provide proof of PCI DSS compliance certification annually, follow SnowBe's vendor management requirements, and cooperate with security reviews.

Policy

To protect cardholder data and comply with PCI DSS v4.0, SnowBe Online must:

- 1. Protect stored cardholder data**
 - Store only the minimum CHD required for business or legal purposes.
 - Mask PAN when displayed; use tokenization or encryption for storage.
- 2. Encrypt cardholder data during transmission**
 - Use TLS 1.2 or higher for all internet transmissions.
 - Never send CHD through unencrypted email or chat systems.
- 3. Maintain a secure network and systems**
 - Install and maintain firewalls between the internet and the CDE.
 - Apply vendor patches and firmware updates within 30 days of release.
- 4. Implement strong access controls**
 - Limit CHD access to those with a business need-to-know.
 - Require multi-factor authentication (MFA) for all administrative users.
- 5. Monitor and test networks**

- Conduct quarterly vulnerability scans by an Approved Scanning Vendor (ASV).
 - Review access logs daily for unauthorized activity.
6. **Maintain an information security policy**
- Review and update this PCI policy annually or when significant changes occur.
 - Train all employees on PCI awareness and secure handling practices.

Exceptions/Exemptions

Any deviation from this plan must be:

1. Submit deviation form to IT Director
2. Approved by the IT Director
3. Documented with compensating controls
4. Time-limited with a remediation deadline

Systems not under SnowBe configuration authority (ex: bank-issued POS terminals) are documented exceptions but still require risk monitoring.

Enforcement

Escalation structure:

1. **Verbal Warning** – first minor policy violation
2. **Written Warning** – documented repeat violations
3. **Suspension of System Access** – short-term, retraining required
4. **Job-related Discipline** – reassignment, loss of privileges
5. **Termination and Legal Action** – for severe/repeated offenses
6. **Criminal Prosecution** – if actions violate state/federal laws

Network or system removal may occur immediately if needed to protect SnowBe systems.

Version History Table

Version #	Implementation Date	Document Owner	Approved By	Description
1.0	Oct 30 th 2025	Ethan Platt	Group2	PCI Policy

PCI Policy– V 1.0

Status: ✖ Working Draft ☐ Approved ☐ Adopted

Document owner: Group 2

DATE: 20251030

Citations

University at Buffalo. (2019, August 19). *Payment Card Industry (PCI) compliance policy*. University at Buffalo Policy Library. <https://www.buffalo.edu/administrative-services/policy-compliance-and-internal-controls/policy/ub-policy-lib/pci-compliance.html>

PCI Security Standards Council. (2022). *Payment Card Industry Data Security Standard: Requirements and testing procedures version 4.0*. PCI Security Standards Council. <https://www.pcisecuritystandards.org>